

TLP:CLEAR

Mailbox Full and Password Reset

One campaign rotating its pretext, not its tooling. July — September 2026

Credential phishing | Self-spoofed service addresses | Kit on reputable platforms | Pretext rotation

Parameter	Value
Event window	5 July — 17 September 2026 (UTC)
Date of analysis	17 September 2026
Classification	TLP:CLEAR
Threat level	MEDIUM
Threat type	Mail credential harvesting; no malicious code in this line
Recipient	A shared mailbox of a human-rights organisation, published on its website
Outcome	No confirmed credential entry; the messages keep arriving

1. In short

From July to September 2026 a shared mailbox of a human-rights organisation has been receiving a continuous series of messages telling the reader that the mailbox is full, that the password has expired, or that the account needs confirming. All of them have the same goal: move the reader to a page that looks like a mail login and take the password.

On its own that is an ordinary story. Three things are worth attention, and all three are visible only across a long series.

- The pretext changed, the tooling did not. On 17 September the sender who had spent two months writing "your mailbox is full" switched the subject to "reset your password". The page the message leads to stayed the same — identical down to the file identifier in storage. These are not two campaigns; they are one, in which the pretext is a consumable.
- Broadcast turned into pressure. In August one and the same message went out to six regional addresses of the organisation — 24 messages in three days. In September the same amount of attention is aimed at a single address: nine messages out of ten.
- Not a single domain of their own. Across the whole period the kit was never hosted on a domain that could be taken out of delegation. Only object storage and public gateways of large providers.

There is one practical conclusion for defenders, and it is inconvenient: a rule that recognises this campaign by the subject line is already out of date — the subject changed once and will change again. Recognition has to rest on how the page is built and on the file identifier, and those hold for weeks.

2. What actually changed in the numbers

Counted by the date the message was sent rather than the date we processed it — otherwise the series shows a spike where there was only a processing delay. The share of messages with the relevant subject across the organisation's whole inbound flow:

Month	Subject "mailbox full"	Subject "password reset/expiry"
July 2026	0.71 per 100 messages	0.31 per 100 messages
August 2026	0.59 per 100 messages	3.64 per 100 messages
September 2026 (17 days)	2.55 per 100 messages	0.75 per 100 messages

The mailbox-full subject grew 4.3 times in a month. The password subject did the opposite: it peaked in August and nearly disappeared. Looking at only one of the two produces a picture that is the reverse of reality — one "falling", one "rising", when in fact it is a single flow that changed clothes between months.

On the single address now under pressure, the share of such messages rose from 5.5 % in August to 20.9 % in September. One in five messages arriving at the organisation's shared mailbox is a lure of this class.

3. Three ways to host a page nobody can take down

At least three branches are involved, and all three solve the same problem: put a login page somewhere it is hard to remove and where the domain raises no suspicion.

The first branch keeps the kit in Backblaze B2 object storage and links to it through the download-file-by-id service endpoint. The file identifier does not change for weeks: the messages of 10, 11 and 17 September all point at the same object. It is the most durable thing in the campaign and the best handle for tracking.

The second branch creates a fresh single-use Cloudflare R2 bucket for every wave. The bucket name changes completely; the file name inside does not — a stable pattern of four letters and seven digits. A fully rotating address with a fixed file name is itself a signature.

The third branch puts the kit into IPFS and links to it through public gateways. Content in IPFS is addressed by hash, so the page is immutable and not tied to a server: it cannot be taken down at all, only gateways can be blocked, and there are many of them.

What all three share is the absence of the thing a complaint is normally aimed at. There is no registrar to revoke a domain and no hosting provider to write to. There is a large, well-regarded platform for which this object is one among billions.

4. The victim's address at the end of the link

In almost every message the link ends with a hash sign and the recipient's address. Technically that is a URL fragment, and it has the property the technique exists for: the browser never sends a fragment anywhere. It stays on the client side and is read by script once the page is open.

Two consequences follow. First, the web server logs show only that the page was fetched, with no record of who it was sent to — which denies the defender any way of establishing the set of addressees from the platform's logs. Second, the page immediately knows whose address to place in the form, so it looks individually prepared even though the run is bulk.

A variant appears where the address is not in the fragment but base64-encoded in a parameter of an intermediate page. Same idea, executed less carefully.

5. Messages that arrive "from the organisation itself"

The sender forges service addresses of the very domain being attacked: the administrative mailbox, the notifications mailbox, the mail server mailbox, the hosting control panel mailbox. The recipient sees a message that formally comes from their own mail service.

This works for a specific reason: the domain policy is set to "put in spam" rather than "reject". When the policy is first configured the difference looks cosmetic; in practice it is decisive — the forgery is delivered, merely to a different folder, and a person still sees it. An organisation whose policy has sat in the intermediate mode for more than a couple of months should treat that as "not done", not as "almost done".

Part of the flow works differently: the address is not forged, only the display name, while the envelope belongs to an unrelated company. We checked: in the cases we analysed this is display-name substitution, not a compromise of someone else's mail. Such domains must not be added to blocklists — a bystander would suffer.

6. Why a series like this is easy to miss

Two mechanisms, both common to many mail pipelines, produce a blind spot on exactly this kind of campaign.

The first is group addresses. Shared mailboxes of the "info@" or "office@" kind are frequently not users but distribution groups, and the administrative interfaces of mail platforms do not return them when enumerating users. A check that asks "have all mailboxes been polled?" then honestly answers "all of

them", because it compares users against users. These are precisely the addresses that take the bulk of the attacks, because they are published on the website.

The second is deduplication by content fingerprint. If a pipeline computes the fingerprint over the plain-text part of a message and the operators put a short stub of a few bytes there, the fingerprint degenerates into a constant. Dozens of different messages collapse into a single "already known" record, and a growing series reads as a long-settled repeat. The check is simple: if a fingerprint has an implausible number of messages under it, look at how long the text under it is.

7. Indicators

Indicators are given defanged. One landing page from the latest wave is deliberately withheld: it may still be live, and publishing it would tell the operator they are being watched while giving defenders nothing.

Type	Value	Note
Landing (IPFS)	bafkreia5iln5dqpy2fejobjp2ojo2rkduchw2tv7xdfjrhbfvvyzhp2i	Kit CID, inbrowser[.]link gateway, 2026-09-11
Landing (IPFS)	bafybeid65s7bjp5kigaj7kbw573wqcz3uiyvzxnxeu5on3tjsoe7nmcsn	Kit CID, file cPweb70.html, dweb[.]link gateway, 2026-09-11
Bucket (R2)	pub-bde527919f074a9d88485c51e0a7c57c.r2[.]dev	Single-use bucket, file sedu8258773.html, 2026-09-04; burned
Bucket (R2)	pub-a4ede915516d42efab13d8916cfb5c1d.r2[.]dev	Same kit, file sedu4257302.html, 2026-09-07; burned
Object storage	f005.backblazeb2[.]com/b2api/v1/b2_download_file_by_id	Kit hosting used by the second operator; fileId reused for weeks
Kit identifier	4_zcc7175a2a5aface295f60211_f104d2b4c7205c55c	fileId fragment shared by the 09-10, 09-11 and 09-17 messages
Bucket (IONOS)	905874987verxgdfsdaswffavdsg79ad77aadfgsbghdr5.s3-eu-central-2.ionoscloud[.]com	Intermediate page, recipient address base64-encoded in the data parameter
Filename pattern	sedu / kedu + 7 digits + .html	Kit filename stays stable while the bucket rotates completely
URL pattern	<landing>#<recipient address>	Victim address in the URL fragment; never sent to the server

Do not block: the domains of the companies in whose name the messages arrived. In the cases analysed this is display-name substitution, not compromise. Also excluded is the compromised webmail panel of an unrelated small business used as an intermediate page — its owner is a victim too.

MITRE ATT&CK techniques: T1566.002 (spearphishing link), T1656 (impersonation), T1583.006 (acquiring web services as infrastructure), T1056.003 (web portal capture), T1102.002 (bidirectional communication over a legitimate web service).

8. What we would suggest

- Do not build rules around the subject line. In this campaign the subject is a consumable, while the identifier of the file holding the kit survives for weeks.
- Treat a link ending in a hash sign followed by the recipient's address as a signal in its own right. Ordinary mail does not do that.
- Move your domain authentication policy to reject. The intermediate mode means forgeries in your own name are delivered to the addressee.
- Check separately whether shared and group addresses are covered by monitoring. Those are the addresses published on the website and the ones taking the traffic.
- Do not count on a domain takedown. In this campaign there is nothing to take down: none of the three branches owns a domain.
- For staff on shared mailboxes: assume that a message "from your mail administrator" arrives in the same mailbox as everything else and looks genuine.

9. What we do not know

Whether anyone entered a password on these pages, we do not know. There are no confirmed cases, but we have no evidence to the contrary either: part of the flow goes to a shared address behind which there is no individual sign-in record.

Whether this is one operator or several working from the same playbook, we did not establish. The branches differ in where the kit is hosted and in how the sender is forged, but they agree on how the page is built and on the address-in-fragment technique. That is enough to speak of a common origin for the kit and not enough to speak of a single person.

We did not open the landing pages themselves. Any request to them would tell the operator they are being watched and could register a fictitious victim. Our reading of the current state of the pages, and of where entered data goes in the latest waves, therefore rests on the structure of previously captured copies of the kit rather than on live observation.

The figures in section 2 are computed over a single organisation. That is a sufficient basis for saying the tactics against it changed, and an insufficient one for transferring the proportions to anybody else.

TLP:CLEAR — This document may be distributed without restriction.